

Ulo engineer security training

Application-specific | Property operations platform

Audience: anyone shipping src/ or supabase/functions/.

Goal: do not leak another landlord's data, do not send money to the wrong Connect account, and do not turn a public token or SMS into an admin action.

This is defensive training for this codebase. It is not a penetration-test playbook and does not include exploit steps or attack payloads.

Stack to keep in mind

Vite + React SPA talks to Supabase (Postgres, Auth, Storage) and Deno Edge Functions. Many Edge Functions use the service role, so Row Level Security does not save a missing filter. Payments go through Stripe. Tenant and vendor messaging goes through SMS.

Module 1 - Tenancy (landlord_id is the wall)

Ulo is multi-tenant. Almost every row is scoped to a landlord.

Rules

- Every query, insert, and workflow run must bind landlordId from a trusted source (session, invite token -> verification row, cron job landlord). Never from an unbound client field.
- Dashboard: getActiveLandlordId() / workspace context. Edge: resolve landlord from the authenticated principal or the token row, then filter .eq("landlord_id", ...).
- Do not load maintenance_requests, vendors, or users by UUID alone.

Discussion exercise

A new Edge action takes { landlordId, ticketId } from the JSON body. What is wrong, and how should it resolve tenancy?

Module 2 - Three auth worlds (do not mix them)

Who	How they prove it	Typical code
Resident / landlord user	Supabase JWT -> auth.getUser	submit-maintenance-request
Property-team admin tools	ADMIN_REASSIGN_SECRET (header or Bearer)	requireAdminReassignAuth
Vendor (portal / SMS)	Portal API key, SMS identity, or /v/:token	vendor-verification, Connect session
Cron / ops	Dedicated secrets; sometimes admin fallback	authorizedCronBearer

Hard facts in this repo

- VITE_ADMIN_REASSIGN_SECRET is a browser env var. Treat it as a dashboard install secret, not a user password. Anyone with the built app can see it. Admin Edges that use it still must be landlord-scoped and must not run as any landlord.
- Never put SUPABASE_SERVICE_ROLE_KEY or STRIPE_SECRET_KEY in VITE_*.
- Many functions set verify_jwt = false and check auth inside the handler. Copying that flag without a real guard is an open endpoint.

Do: reuse requireAdminReassignAuth, proxied_message_auth, and token lookup on vendor_verifications. Do not invent a fourth header or a temporary unauthenticated POST.

Module 3 - Public links

Unauthenticated pages are first-class attack surface: /v/:token, work orders, estimates, and /pay/rent.

Rules

- Tokens must be unguessable. Never sequential IDs in the URL.
- A token proves that vendor, job, or payment - not admin. Create Connect Account Sessions from the row's acct_id, never from a client-supplied account id.
- On save/submit, reload the row by token and ignore extra landlordId / vendorId in the body.
- W-9: store last4 + fingerprint, not the full TIN.
- Payout UI: masked last4 only (loadPayoutMethods).

Discussion exercise

Why create_account_session must not accept accountId from the browser.

Module 4 - Money (Stripe)

Keep the two money paths separate. Destinations, payers, and ledgers differ.

Flow	Direction	Destination
Rent	Tenant -> landlord	Landlord Connect
Invoice	Landlord -> vendor	Vendor Connect

Ready means a valid acct_id AND charges_enabled === true. Use isStripeConnectReady (edge: _shared/stripeConnect.ts; client: src/lib/stripeConnectReady.ts). Do not invent a second check.

Rules

- Never send landlord Connect as an invoice destination, or vendor Connect as rent.
- Do not trust client amount or destination without server-side ticket and policy.
- Live Connect return URLs must be HTTPS. Localhost plus sk_live_ fails for hosted links.

Module 5 - SMS and conversations

Inbound SMS is a trusted control plane (YES/NO, STOP, cancel work orders).

Rules

- Handler registry: one message -> one action, only with stored pending context. Do not add a keyword handler that mutates tickets without a pending ask.
- Cancel must close the ticket and the workflow run (closeWorkOrderCancelledByResident).
- Do not treat status questions as new work orders.
- Admin SMS (admin-conversation-sms) still needs tenancy and auth.
- STOP/HELP are compliance. Do not retry welcome SMS after STOP.

PII: threads contain phones, addresses, and unit numbers. Do not log full bodies to third parties. Activity feed copy stays landlord-facing, not raw payloads.

Module 6 - Data writes and the graph

- Edge Functions with the service role bypass RLS. Your filter is the security model.
- Never raw-insert operations_graph_events or property_operations_graph. Use recordActivityLog.
- New migrations only. Do not edit old migration files.
- Storage: signed URLs / policies. Do not make maintenance uploads world-readable.

Module 7 - Secrets and shipping

Goes in the browser	Stays on Edge / CI
VITE_SUPABASE_ANON_KEY	SUPABASE_SERVICE_ROLE_KEY
VITE_STRIPE_PUBLISHABLE_KEY	STRIPE_SECRET_KEY
VITE_ADMIN_REASSIGN_SECRET (known limitation)	Cron / misconduct / similar secrets

- Do not commit .env.
- Align Dashboard Edge ADMIN_REASSIGN_SECRET with local VITE_ADMIN_REASSIGN_SECRET or admin actions 401.
- Deploy the function you changed. A SPA deploy does not update Deno.

90-minute workshop

- 20 min - Walk a request: vendor /v/:token -> vendor-verification -> service role -> landlord_id on the row.
- 20 min - Walk rent vs invoice Connect.
- 20 min - Walk SMS inbound: registry vs workflow engine.
- 20 min - Run the PR threat checklist on a real recent PR.
- 10 min - Q&A: would I put this in VITE_?

PR threat checklist

Paste into reviews:

- [] Landlord scope from a trusted binding, not a free-form id
- [] Auth matches the actor (JWT vs admin secret vs token vs cron)
- [] No service role in the client

- [] Money: correct Connect destination + shared readiness helper
- [] Public token cannot change another vendor or landlord
- [] SMS: pending gate; cancel closes workflow runs
- [] recordActivityLog for state changes
- [] Secrets not in git; new Edge verify_jwt / handler auth is explicit

Ulo internal training. For questions, review `supabase/functions/_shared/admin_edge_auth.ts`, `stripeConnect.ts`, and the SMS inbound handler registry.